信息安全测评与风险评估

6.2 系统整体测评结论形成

授课教师：张玉



目录

CONTENTS

01 案例导入

02 学习目标

03 整体测评结论——在等保报告中的定位

04 整体结论的三种类型

案例导入

引入问题：单项测评结论都是“符合”，系统就一定是安全的吗？

案例素材

某政务系统等保测评中，项目经理查看单项结论发现：

- 物理环境 / 通信网络 / 区域边界：**全部“符合”**
- 安全计算环境：15项“符合”，**1项“部分符合”**
- 安全管理：10项“符合”，**2项“部分符合”**

结论：项目经理认为总体不错，直接给出“基本符合”结论。

专家复评质疑

1. 1项计算环境指标恰好是**“数据备份恢复”**——无异地备份。
2. 2项管理指标涉及**“应急预案与事件处置”**——制度缺失。

专家指出：整体结论不仅看“符合”数，更看“不符合/部分符合”的位置和权重。

问题讨论

- 该项目经理的做法有什么问题？
- 整体结论应该怎么做？“部分符合”权重一样吗？

学习目标

01

理解

系统整体测评结论的形成原理（从“零件”到“整车”）

02

掌握

单项结论汇总分析的方法与步骤

03

能够

运用风险趋势判断法识别“高风险集中领域”

04

能够

规范撰写系统整体测评结论

05

具备

从“局部”到“整体”的综合安全判断能力

整体测评结论——在等保报告中的定位

等保测评报告结构：

封面 > 概述 > 测评范围 > 单项结果 > **整体结论** > 问题汇总 > 整改建议

整体结论是什么？

概念	说明
定义	在汇总全部单项测评结论基础上，对对象的整体安全状况作出的综合性评价
作用	回答“这个系统到底安不安全”这个核心问题
表现形式	通常以“符合/基本符合/不符合”三种结论之一呈现

一句话概括：单项结论是“体检报告”里的科室检查，整体结论是“主治医生的综合诊断”。

整体结论的三种类型

符合	**判断标准：**所有测评指标均为“符合” **常见场景：**系统安全状况良好，无任何差距
基本符合	**判断标准：**存在“部分符合”或“不符合”项，但无重大安全隐患 **常见场景：**系统存在一般性差距，整改后可达标
不符合	**判断标准：**存在重大安全隐患或关键指标不符合 **常见场景：**系统存在高危漏洞、核心数据未保护等

从单项结论到整体结论——三个关键步骤

01

步骤1：汇总统计

操作：统计各等级结论的数量

具体方法：按“符合/部分符合/不符合/不适用”分类计数

工具：测评结论汇总表

02

步骤2：风险分析

操作：分析“部分符合/不符合”项的风险严重程度

具体方法：识别高危风险项、关注风险集中领域

工具：风险趋势判断法

03

步骤3：综合判断

操作：结合“数量+位置+风险”形成整体结论

具体方法：判断是否存在重大安全隐患

工具：综合判断矩阵

步骤1——单项结论汇总统计

教师演示： 展示一份测评结论汇总表，带领学生统计

测评结论汇总表

测评大类	总指标数	符合	部分符合	不符合	不适用
安全物理环境	10	8	2	0	0
安全通信网络	4	3	1	0	0
安全区域边界	5	4	0	1	0
安全计算环境	12	8	2	1	1
安全管理	15	10	3	2	0
合计	46	33	8	4	1

统计结论：

符合率 =**33/46 ≈ 72%**，存在**8项**“部分符合”和**4项**“不符合”——仅看数字，整体情况似乎“还可以”。

步骤2——风险趋势判断法（核心方法）

教师演示： 识别“部分符合/不符合”项中的“高风险项”

风险趋势判断法——三个维度：

指标性质

S类（信息安全）/A类（服务保证）/G类（通用），S类/A类指标不合规风险更高

安全层面

技术 / 管理，技术类不合规往往更直接、更紧迫

系统影响范围

局部 / 全局，影响范围越广，风险越高

高风险项目示例：

项目	状态	分析说明	风险等级
数据备份恢复	部分符合	A类，系统无异地备份，数据丢失风险高	高
入侵防范	不符合	S类，存在未修复高危漏洞	高

– 步骤3——综合判断矩阵

- **教师演示： 如何结合“数量+位置+风险”得出最终结论**

不符合项	高风险项	整体结论	说明
0	否	符合	全部符合，无需整改
1-3	否	基本符合	存在一般性差距，可整改达标
4-6	否	基本符合	需要较全面整改
≥7	否	基本符合（建议重点关注）	整改工作量大
任意	**是**	**不符合**	**存在重大安全隐患**

整体结论的撰写规范

01

总体评价

一句话概括系统整体安全状况

示例

“XX系统整体安全状况良好，基本符合等级保护第三级要求”

02

符合情况

用数据说明整体符合程度

示例

“本次测评共46项指标，符合33项，部分符合8项...”

03

主要问题

概括“不符合项”和“部分符合项”的主要问题

示例

“主要问题集中在数据备份恢复、入侵防范等方面”

04

风险趋势

判断系统面临的主要风险

示例

“系统存在数据丢失风险、网络攻击风险等”

05

最终结论

明确给出整体结论类型

示例

“综合判定：XX系统不符合等级保护第三级要求”

整体结论撰写示例

符合	“XX系统本次测评共涵盖46项测评指标，全部符合要求。系统在安全物理环境、通信网络、区域边界、计算环境、安全管理等方面均达到等级保护第三级标准，整体安全状况良好，能够有效抵御相应的安全威胁。”
基本符合	“XX系统测评46项指标，符合33项，部分符合8项，不符合4项，符合率72%。主要问题：无异地备份、未修复高危漏洞、应急预案制度缺失。存在数据丢失和网络安全风险。判定：基本符合三级要求，建议整改。”
不符合	“XX系统测评46项指标，符合28项，不符合8项，符合率61%。发现多项高危风险：无异地备份、高危漏洞(CVE-2017-5638等)、Telnet明文传输、管理制度缺失。构成重大隐患。判定：不符合三级要求。”

实践任务1——单项结论汇总分析

要点一

任务名称

测评结论汇总与风险趋势分析

要点二

任务场景



素材1：单项测评结论清单（用于实践

教师提供一份模拟的单项测评结论清单（见素材1）

要点三

任务内容

① 按大类统计各等级结论数量 → ② 标记“高风险项” → ③ 判断整体结论类型

要点四

成果形式



素材2：整体结论判断表.docx

填写《整体结论判断表》（见素材2）

实践任务2——撰写整体测评结论

任务名称

撰写系统整体测评结论

素材3：整体结论参考模板.docx

任务场景

基于任务1的汇总结果

任务内容

依据汇总分析和风险判断，撰写一份完整的整体测评结论

素材4：高风险项快速判定卡.docx

成果形式

提交《整体测评结论初稿》

常见错误与避坑指南

错误类型	错误表现	正确做法
只数数量，不看位置	只有4项不符合，总体应该算基本符合	要看这4项是不是核心指标（如数据备份、入侵防范等）
忽视高风险项	只有1项不符合，应该问题不大	1项不符合也可能直接导致整体结论为不符合
结论与描述矛盾	正文说存在多项高危风险，结论却是基本符合	结论必须与风险分析一致
结论过于模糊	系统安全状况尚可	整体结论必须明确为符合/基本符合/不符合

思政融入——整体结论中的职业责任

担当

整体结论是测评报告的“结论”，客户领导要看，监管部门要看。一句话可能决定一个系统能否上线运行。

客观

不看“面子”，只看“里子”。不因为客户“重要”就放松标准，不因为问题“麻烦”就回避不报。

系统思维

单项合格≠整体安全——这个认识，是测评师专业能力的体现。安全是一个整体，不能在“木桶”上有明显短板。

知识点回顾

本课核心知识

- **一、整体结论的三种类型**
  - - 符合（全部符合）
  - - 基本符合（存在一般性问题）
  - - 不符合（存在重大安全隐患）
- **二、形成三步骤**
  - - 1. 汇总统计（分类计数）
  - - 2. 风险趋势判断（识别高风险项）
  - - 3. 综合判断（数量+位置+风险）
- **三、风险趋势判断法**
  - - 指标性质（S/A/G）
  - - 安全层面（技术/管理）
  - - 影响范围（局部/全局）
- **四、撰写规范**
  - - 总体评价 + 符合情况
  - - 主要问题 + 风险趋势
  - - 最终结论

课后作业

- **【必做】** 完成《整体结论判断表》并提交至学习通平台
- **【必做】** 完成作业：6.2 整体测评结论形成
- **【选做】** 阅读一份真实测评报告（脱敏版）的“整体结论”部分，分析其结构
- **【预习】** 预习6.3“编制完整等保测评报告”相关内容

下节课预告

任务6.3：编制完整等保测评报告

预告内容

- 整合全部测评成果（单项结论+整体结论+整改建议）
- 等保测评报告的整体格式
- 报告审核与修订流程

课前准备

- 复习前序项目（项目1-5）的测评记录
- 阅读测评报告模板

感谢观看

